

Theoretical Foundation of ZK-SNARK Video Steganography

VideoLevel technical design note

19 September 2026 (revised 3 October 2026)

Abstract

This design note formalizes the construction currently implemented by VideoLevel. A message m and a compressed Groth16 proof π are packed into a payload, wrapped in an HMAC-authenticated frame, whitened with an HMAC keystream and written into the first trailing-one sign bit of selected CAVLC residual blocks of H.264 IDR slices. Positions are chosen by a keyed pseudorandom schedule, so extraction is blind: it needs neither the cover video nor a sidecar. The note states each security property together with the assumption it rests on, and lists the properties the construction does not provide.

Update 03/10/2026. This revision replaces the earlier description. The key schedule is now protocol v2 (HKDF-separated subkeys, per-segment HMAC ordering, frame whitening); the circuit constrains every hash and secret signal to be boolean; verification is blind extraction followed by mandatory Groth16 verification. The former Python pipeline (Python CAVLC parser, position safety filter, chaos maps for bit/position scrambling, `positions.json` sidecars, strict mode that re-parsed the original cover, and the SEC1–SEC10 benchmark suite) has been removed and is *not* part of the system described here. In particular, no chaos-map theory applies to the current construction. Streams produced by protocol v1 cannot be read by v2.

1 Notation and trust boundary

Bytes are big-endian and bit strings are MSB-first. $uk(x)$ denotes the k -bit big-endian encoding of an integer x , $X[a:b]$ the byte slice $a, \dots, b-1$, and $\text{HMAC}(k, x)$ always means HMAC-SHA256. Let V be a Baseline-profile H.264 Annex-B elementary stream, m a non-empty byte string, and $K \in \{0, 1\}^{256}$ a 32-byte secret shared by embedder and receiver. Let $\beta \geq 1$ be the per-segment bit budget (`max_bits_per_IDR`) and $L_{\max}$ the configured maximum payload size (4096 bytes in the native CLI; the frame format allows up to $2^{16} - 1$). Both β and $L_{\max}$ are public parameters that embedder and receiver must agree on.

The embedder outputs a stego stream V' only; no sidecar is produced. The receiver holds V' , K , β , $L_{\max}$ and the Groth16 verification key vk . The secret K and message m must never be written to job status records, logs or benchmark artifacts.

2 Carrier: trailing-one sign bits

CAVLC codes each 4×4 (or DC) residual block as the syntax element `coeff_token` (the pair (TotalCoeff, TrailingOnes), VLC table chosen by nC), one `trailing_ones_sign_flag` per trailing one, the remaining levels, `total_zeros` and `run_before`.

Definition 1 (Candidate). Let $\sigma = (\text{SPS}, \text{PPS}, \text{IDR})$ be a segment. For every residual block of category $t \in \{0, 1, 2, 3\}$ (LumaDC, Luma4×4, ChromaDC, ChromaAC) in the IDR slice with `TrailingOnes` ≥ 1 , the candidate is the *first* `trailing_ones_sign_flag` of that block in bitstream order. It is identified by

$$\text{id}(c) = \text{ASCII}(n : a : t : b : o),$$

where n is the NAL index inside the segment, a the macroblock address, b the block index, and o the RBSP bit offset of the sign flag. $C(\sigma)$ denotes the set of candidates of σ ; at most one candidate exists per block.

Property 1 (Length and context preservation). Flipping a candidate sign changes one coefficient from ± 1 to ∓ 1 and leaves TotalCoeff, TrailingOnes, every codeword length and every nC value unchanged. Hence the RBSP length, all RBSP bit offsets, the parse of every later syntax element, and $C(\sigma)$ itself are identical in cover and stego. (Emulation-prevention bytes are re-inserted when RBSP is converted back to Ebsp, so Ebsp byte offsets may shift; identities use RBSP offsets.)

Property 1 follows from the CAVLC syntax and is checked bit-exactly by the implementation; it is what makes blind extraction possible: the receiver recomputes $C(\sigma)$ from V' . A flip still changes the decoded picture (a dequantized coefficient change of magnitude 2 at quantized level, propagated through intra prediction and deblocking); imperceptibility is an empirical property measured by decoded PSNR/SSIM, not a theorem. Only IDR slices carry bits; non-IDR NAL units are copied unchanged.

3 Key schedule (protocol v2)

Definition 2 (Subkeys). With HKDF-SHA256 (RFC 5869),

$$\begin{aligned} \text{PRK} &= \text{HMAC}(\text{"zkstego-cavlc-v2-salt"}, K), \\ K_s &= \text{HKDF-Expand}(\text{PRK}, \text{"zkstego/cavlc/v2/schedule"}, 32), \\ K_f &= \text{HKDF-Expand}(\text{PRK}, \text{"zkstego/cavlc/v2/frame-tag"}, 32), \\ K_w &= \text{HKDF-Expand}(\text{PRK}, \text{"zkstego/cavlc/v2/whitening"}, 32). \end{aligned}$$

Definition 3 (Segment schedule). Let V' be split into segments $\sigma_0, \sigma_1, \dots$, one per IDR NAL, each consisting of the latest SPS and PPS followed by that IDR. In segment σ_j , order the candidates by the key $(\text{HMAC}(K_s, \text{id}(c)), \text{id}(c))$ ascending (lexicographically on bytes) and keep the first

$$q_j = \min(\beta, |C(\sigma_j)|)$$

candidates. Concatenating these lists over $j = 0, 1, \dots$ gives the global position sequence $p_0, p_1, \dots$; frame bit i is written at p_i . Bit indices continue across segments; scheduled positions beyond the frame length keep their cover sign. Embedding fails if $\sum_j q_j < |F|$, where $|F|$ is the frame length in bits.

The identity contains no sign value and $C(\sigma_j)$ is sign-invariant (Property 1), so a receiver with K and β reproduces $p_0, p_1, \dots$ exactly from V' . A mismatched β yields a different schedule and extraction fails.

4 Authenticated, whitened frame

Definition 4 (Frame and embedded bits). For a payload P with $|P| \leq L_{\max}$,

$$F = 0x02 \parallel \text{u16}(|P|) \parallel P \parallel \text{HMAC}(K_f, 0x02 \parallel \text{u16}(|P|) \parallel P)[0:16].$$

The whitening keystream is $S = \text{HMAC}(K_w, \text{u64}(0)) \parallel \text{HMAC}(K_w, \text{u64}(1)) \parallel \dots$ and the embedded bit at p_i is

$$e_i = F_i \oplus S_i, \quad \text{sign}(p_i) = \begin{cases} + & e_i = 0 \\ - & e_i = 1. \end{cases}$$

The frame overhead is $1 + 2 + 16 = 19$ bytes, so $|F| = 8(|P| + 19)$ bits.

Blind extraction. (1) Parse the IDR segments of V' and enumerate $C(\sigma_j)$. (2) Derive K_s, K_f, K_w and the schedule. (3) Read and de-whiten the first 24 bits; reject unless the version is `0x02` and `u16 length` $\leq L_{\max}$. (4) Read the remaining $8(|P| + 16)$ bits, de-whiten, recompute the tag and compare in constant time; reject on mismatch or if the stream ends early. With a wrong key the de-whitened version byte is essentially random, so most wrong keys are rejected at step (3) and the rest at step (4).

5 Payload and zero-knowledge relation

Definition 5 (Payload). $P = \text{u32}(|m|) \parallel m \parallel \pi$, where π is a Groth16 proof over BN254 compressed to 129 bytes (the x -coordinates of $A \in G_1, B \in G_2$ (two $\mathbb{F}_p$ elements), $C \in G_1$, 32 bytes each, plus one byte holding the three y -parity bits).

The length field gives an unambiguous message/proof split. With $L_{\max} = 4096$ the largest message is $4096 - 4 - 129 = 3963$ bytes. Decompression rejects coordinates $\geq p$ and points not on the curve.

Definition 6 (Relation). The circuit `payload_verify.circom` (63 321 constraints, 513 public signals) defines

$$\mathcal{R} = \left\{ (h, c, \ell; s) : c = \text{SHA256}(h \parallel s), h, c, s \in \{0, 1\}^{256}, 0 < \ell < 10^6 \right\},$$

where the booleanity of every bit of h, c and s is enforced by $x(x-1) = 0$ constraints. The prover uses $h = \text{SHA256}(m)$, computed *outside* the circuit, $s = K$ and $\ell = |m|$; the public statement is (h, c, ℓ) and the witness is s .

The booleanity constraints are necessary for soundness: `circomlib`'s `Sha256` gadget does not constrain its inputs to bits, so without them a prover could feed arbitrary field elements into the hash. Note that ℓ is only range-checked inside the circuit; the circuit does not relate ℓ to h . The link between ℓ, h and m is established by the verifier recomputing both from m .

Verification. The receiver accepts (m, π) if and only if all of the following hold: blind extraction returns a frame with a valid tag; P unpacks into `u32(|m|) || m ||  $\pi$` with a valid 129-byte encoding; and

$$\text{Groth16.Verify}(\text{vk}, (h, c, \ell), \pi) = 1 \quad \text{with} \quad h = \text{SHA256}(m), c = \text{SHA256}(h \parallel K), \ell = |m|$$

recomputed by the receiver (public signals supplied by the sender are never used). The HTTP verify job reports `rejected` with reason `payload_not_authenticated`, `malformed_proof_payload` or `proof_invalid` when the corresponding step fails.

6 Security properties

Assumption 1 (Standard primitives). (A1) HMAC-SHA256 is a pseudorandom function (PRF) when keyed with a uniformly random 32-byte key; consequently HKDF-SHA256 is a secure KDF and K_s, K_f, K_w are computationally independent pseudorandom keys when K is uniform. (A2) SHA-256 is collision resistant. (A3) Groth16 is knowledge-sound and zero-knowledge in the generic-group/algebraic model, *provided* the setup was generated honestly and its trapdoor destroyed.

The following properties hold under Assumption 1; they are standard reductions and no stronger claim is made.

Property 2 (Pseudorandom schedule). For a party without K , the ranking of candidates in every segment is computationally indistinguishable from a uniformly random permutation chosen independently of the cover (by A1 applied to K_s , given distinct identities). Hence the selected positions are pseudorandom to such a party.

Property 3 (Frame authenticity). A party without K that may observe valid frames and makes at most Q verification attempts produces a new frame with a valid tag with probability at most $\text{Adv}_{\text{HMAC}}^{\text{prf}} + Q 2^{-128}$, since the tag is a 128-bit truncation of a PRF output. A valid tag therefore shows that the frame was produced by a holder of K (or of K_f) and was not modified.

Property 4 (No fixed-header bias). For a single frame per key, S is indistinguishable from uniform by A1 applied to K_w , so the embedded bits e_i are pseudorandom even though F has a fixed version byte, small length field and structured proof bytes. Selected signs therefore carry no fixed header pattern.

Property 5 (Subkey separation). Disclosure of one subkey (e.g. K_s) reveals neither K nor the other subkeys, by A1 applied to PRK and the HKDF-Expand outputs.

Property 6 (What the proof shows). If Verify accepts, then by A3 the prover knew s with $\text{SHA256}(\text{SHA256}(m) \parallel s) = c = \text{SHA256}(\text{SHA256}(m) \parallel K)$, and by A2 $s = K$ except with negligible probability. Groth16 zero-knowledge means π reveals nothing about s beyond this statement.

Properties not provided

- **No binding to video, segment or session.** Neither F nor $\mathcal{R}$ contains a video hash, segment index, timestamp, nonce or camera identity. A payload extracted from one stream can be re-embedded into another stream under the same K and will verify (replay).
- **No public verifiability.** The verifier needs K both to extract (schedule, whitening, tag) and to recompute $c = \text{SHA256}(h \parallel K)$. Anyone able to verify can also produce a valid proof, so in the current configuration π attests knowledge of the same shared secret that the HMAC tag already attests; it is not evidence towards third parties.
- **No nonce in whitening.** S depends only on K . Embedding two frames under the same K reuses the keystream; the guarantee above is per single frame per key. Positions remain hidden, which limits but does not remove this leakage. Whitening is not an IND-CPA encryption of m .
- **No undetectability proof.** Pseudorandom positions and bits do not imply that the sign changes are statistically undetectable relative to natural cover statistics; detectability must be measured.
- **Trusted setup.** The current proving/verification keys are a local educational setup (`DEMO_SETUP_ONLY.txt`); whoever holds the trapdoor can forge proofs. A3 does not hold for it in a deployment sense.
- **Robustness.** The channel is fragile by design: any re-encode, transcode or bit error in a selected sign breaks the tag.

7 Algorithms

Embedding

1. Validate $|K| = 32$, $0 < |m|$, $4 + |m| + 129 \leq L_{\max}$; load circuit artifacts.

2. Compute $h = \text{SHA256}(m)$, $c = \text{SHA256}(h \parallel K)$ and $\ell = |m|$. Run Groth16, $\pi \leftarrow \text{Prove}(\text{pk}; (h, c, \ell); K)$, and compress π to 129 bytes.
3. Derive K_s, K_f, K_w ; form P and F ; for each IDR segment in order, schedule q_j positions and set $\text{sign}(p_i)$ from e_i until all $|F|$ bits are placed.
4. Re-insert emulation prevention and emit V' ; later NAL units are copied.

Verification

1. Blind extraction (Section efsec:frame) with $K, \beta, L_{\max}$; reject on version, length, capacity or tag failure.
2. Unpack P , decompress π , reject malformed encodings before pairing checks.
3. Recompute (h, c, ℓ) from (m, K) and run Groth16 verification; accept only on success.

8 Capacity and evaluation quantities

The capacity of a stream is $\sum_j \min(\beta, |C(\sigma_j)|)$ bits and a message of $|m|$ bytes needs $|F| = 8(|m| + 4 + 129 + 19) = 8(|m| + 152)$ bits. For example, an 8-frame CIF all-intra clip at QP 22 has 3660 candidates; a 19-byte message needs 1368 bits (a 171-byte frame), about 37% of the candidates. Evaluations should report candidate counts, scheduled bits, decoded quality (full-video and minimum modified-frame PSNR, SSIM), verification outcome and latency per stage separately; measured values are artifact-specific, not guarantees. The strongest regime is all-intra Baseline CAVLC; with $\text{GOP} > 1$, P-frames referencing modified IDR frames inherit the distortion and need separate measurement.

9 Operational surface

The HTTP service exposes public `/health` and bearer-token-protected `embed`, `extract`, `verify`, `status` and one-time artifact download jobs plus a WebSocket stream endpoint. The token (`ZK_STEGO_API_TOKEN`, at least 32 characters) is checked before the body is read; repeated authentication failures are rate-limited; uploads, concurrency and job queues are bounded. Status records never contain K , m or stack traces. Native processes are run without a shell and with timeouts.

The signed-manifest and expiring-certificate modules (Ed25519) remain in the repository as auxiliary trust interfaces but are not part of the embedding or verification path above. An offline verifier can reject an expired certificate, but cannot prevent use of a copied key with a modified clock; hard expiry needs an online lease, trusted time or hardware-enforced key.

10 Limitations and target design

The native parser accepts only Baseline CAVLC, progressive 4:2:0, one slice per frame starting at macroblock 0, no I_PCM, and a single SPS/PPS id. Realtime throughput on a physical camera has not met the 30-FPS gate.

`future_plan.md` describes a target design that is **not implemented**: a relation over a media root, session and segment index, previous-record digest, policy digest and a camera/registry credential; a public, sign-independent carrier schedule so that verification no longer needs a shared secret; segment chaining with a final seal; and removal of HMAC from the acceptance condition once those components pass their gates. None of the properties of that design should be attributed to the current construction.